

ДЕПАРТАМЕНТ ОБРАЗОВАНИЯ ТОМСКОЙ ОБЛАСТИ

ОБЛАСТНОЕ ГОСУДАРСТВЕННОЕ БЮДЖЕТНОЕ
ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ
«ТОМСКИЙ ТЕХНИКУМ ИНФОРМАЦИОННЫХ ТЕХНОЛОГИЙ»

Специальность 09.02.07 и программирование
Специальность 09.02.07 Информационные системы и программирование

Отчёт о лабораторно-практической работе № 4
по дисциплине МДК.07.02
«Стандарты и спецификации в области информационной безопасности»

Студент гр. 622
7 мая 2025 г.

_____ В. В. Силаев

Преподаватель
7 мая 2025 г.

_____ Ю. С. Чернова

Томск 2025

Цель:

Научиться разрабатывать политику информационной безопасности, основываясь на международных стандартах и спецификациях, а также адаптировать ее под конкретные условия организации.

Задание:

1. Выбор организации: Нужно выбрать реальную или вымышленную организацию (например, малый бизнес, государственное учреждение, образовательное учреждение и т.д.), для которой будет разрабатываться политика информационной безопасности.

2. Изучение стандартов: Выбрать один или несколько стандартов в области информационной безопасности, таких как:

- ISO/IEC 27001
- NIST SP 800-53
- PCI DSS
- CIS Controls (Центр интернет-безопасности)
- GDPR

3. Анализ потребностей: Нужно провести анализ потребностей выбранной организации в области информационной безопасности:

- Определение активов информации (данные, системы, оборудование)
- Оценка рисков (угрозы, уязвимости)
- Определение требований к соблюдению законодательства и стандартов

4. Разработка политики: На основе проведенного анализа разработать политику информационной безопасности, которая должна включать:

- Введение (цели и задачи политики)
- Область применения (кто и что охватывает политика)
- Основные принципы безопасности (например, управление доступом, защита данных, инцидент-менеджмент)
- Ответственности и роли (кто отвечает за выполнение политики)
- Процедуры и меры контроля (как будет осуществляться контроль за соблюдением политики)

ЗАДАНИЕ

Организация: ПАО «Сбербанк». (Рисунок 1 — логотип сбербанка)



Рисунок 1 - логотип сбербанка

Сфера деятельности: Финансовые услуги (банкинг, инвестиции, страхование, цифровые платформы).

Особенности:

- 1) работа с персональными данными клиентов и финансовой информацией;
- 2) высокие требования к защите платежных систем (PCI DSS);
- 3) регуляторные требования Центрального банка РФ и международных стандартов;
- 4) глобальное присутствие (необходимость соответствия GDPR для клиентов из ЕС).

Выбранные стандарты:

- 1) ISO/IEC 27001 (управление системами ИБ).
- 2) PCI DSS (защита данных платежных карт).
- 3) GDPR (защита персональных данных граждан ЕС).

Анализ потребностей.

Информационные активы:

Данные: Персональные данные клиентов (например прописка и т.д), финансовые транзакции, логины и пароли, кредитные истории и т.д.

Системы: Платежные системы (СПФС), мобильное приложение «СберБанк Онлайн», серверы ЦОД, CRM.

Оборудование: Банкоматы, POS-терминалы, рабочие станции сотрудников.

Оценка рисков:

Формат (Угрозы — Уязвимости - Риски)

Кибератаки (фишинг, DdoS) – Устаревшее ПО на периферийных устройствах - Высокий (потеря данных).

Утечки данных - Недостаточный контроль доступа - Высокий (репутационные потери)

Требования к соблюдению:

1) законодательство РФ: 152-ФЗ «О персональных данных», требования ЦБ РФ (Стандарт СТО БР ИББС).

2) международные стандарты: PCI DSS (для обработки карточных транзакций), GDPR (для клиентов ЕС).

Разработка политики.

Цели:

1) обеспечить защиту конфиденциальности, целостности и доступности данных клиентов, сотрудников и партнеров;

2) минимизировать риски кибератак, утечек данных и внутренних угроз;

3) соответствовать требованиям международных стандартов (ISO 27001, PCI DSS, GDPR) и российского законодательства (152-ФЗ, Стандарт ЦБ РФ СТО БР ИББС).

Задачи:

- 1) внедрение систем управления доступом и мониторинга угроз;
- 2) регулярное обучение сотрудников в области ИБ;
- 3) создание механизмов быстрого реагирования на инциденты.

Область применения.

Информационные активы:

- 1) персональные данные клиентов (ФИО, паспортные данные, платежные реквизиты);
- 2) финансовая информация (транзакции, кредитные истории, инвестиционные портфели);
- 3) корпоративные данные (внутренние документы, логи доступа).

ИТ-инфраструктура:

- 1) серверы ЦОД, облачные платформы (SberCloud), банкоматы, POS-терминалы, мобильное приложение «СберБанк Онлайн»;
- 2) сети передачи данных (LAN, WAN, VPN).

Ответственные лица:

- 1) все сотрудники (включая временных и удаленных);
- 2) подрядчики и партнеры, имеющие доступ к системам Сбербанка;
- 3) руководство (утверждение политики, контроль исполнения).

Основные принципы безопасности

- 1) реализация модели «Need-to-know»;

- 2) двухфакторная аутентификация для доступа к критическим системам;
- 3) шифрование данных на всех этапах (PCI DSS Requirement 4);
- 4) регулярное резервное копирование (ISO 27001, раздел A.12.3);
- 5) создание CERT-команды для реагирования на инциденты;
- 6) обязательная отчетность об утечках в 72 часа (GDPR Article 33).

Ответственности и роли:

- 1) руководство Сбербанка: Утверждение политики, выделение ресурсов;
- 2) служба ИБ: Мониторинг угроз, проведение аудитов;
- 3) сотрудники: Соблюдение правил ИБ, прохождение ежегодного обучения.

Процедуры и меры контроля

Аудит: Ежегодная проверка на соответствие ISO 27001 и PCI DSS.

Обучение: Обязательные тренинги по фишингу и работе с персональными данными.

Технические меры:

- 1) внедрение SIEM-систем для анализа угроз;
- 2) сегментация сетей (PCI DSS Requirement 1).